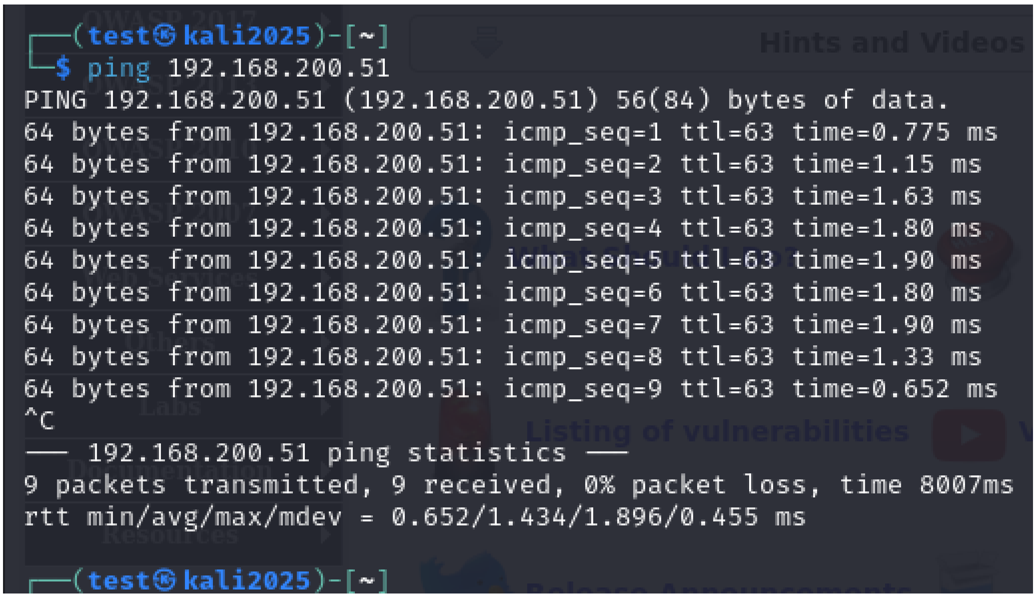
mellouk   Brèche sur des informations confidentielles   1 btsA
monib

Travail a faire 1

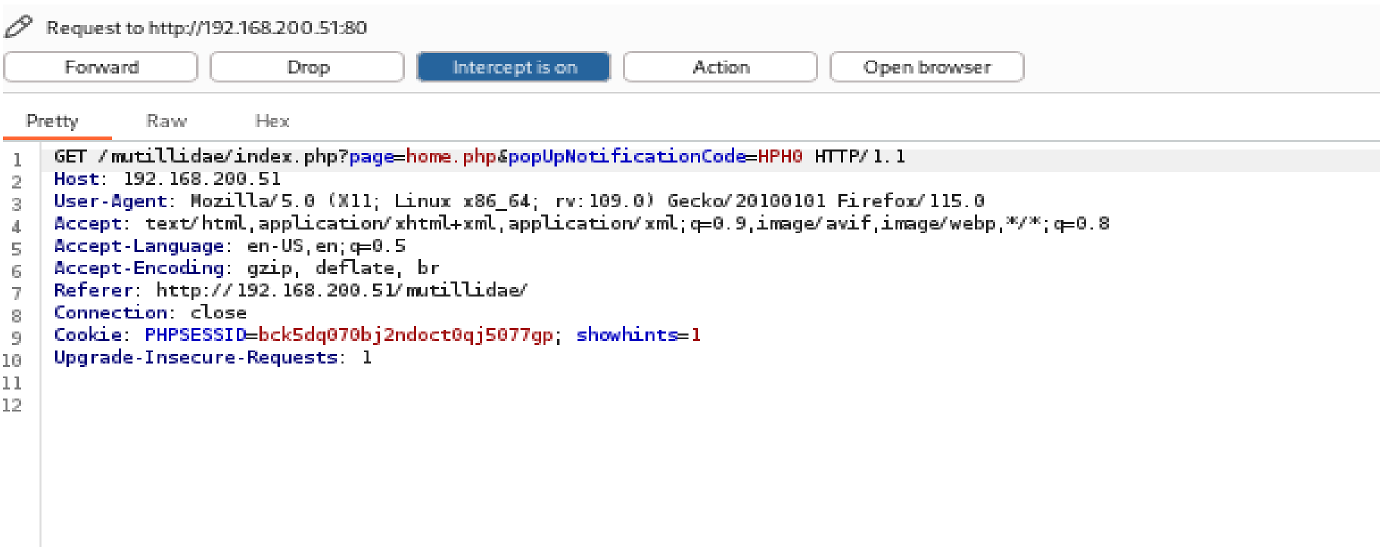
question 1:

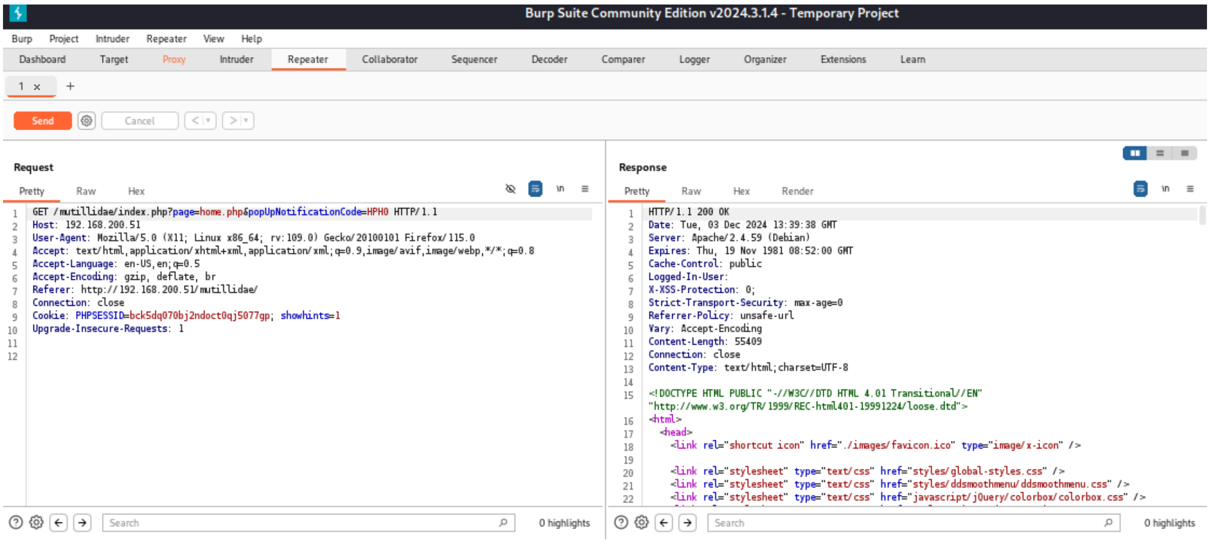
ping de la kali vers la mutillidae

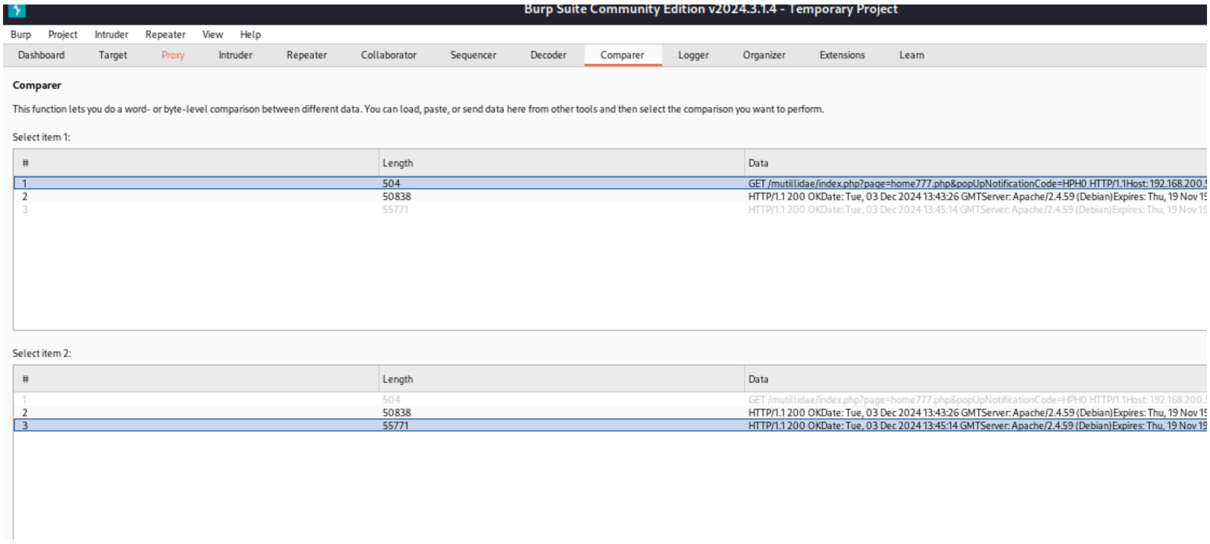


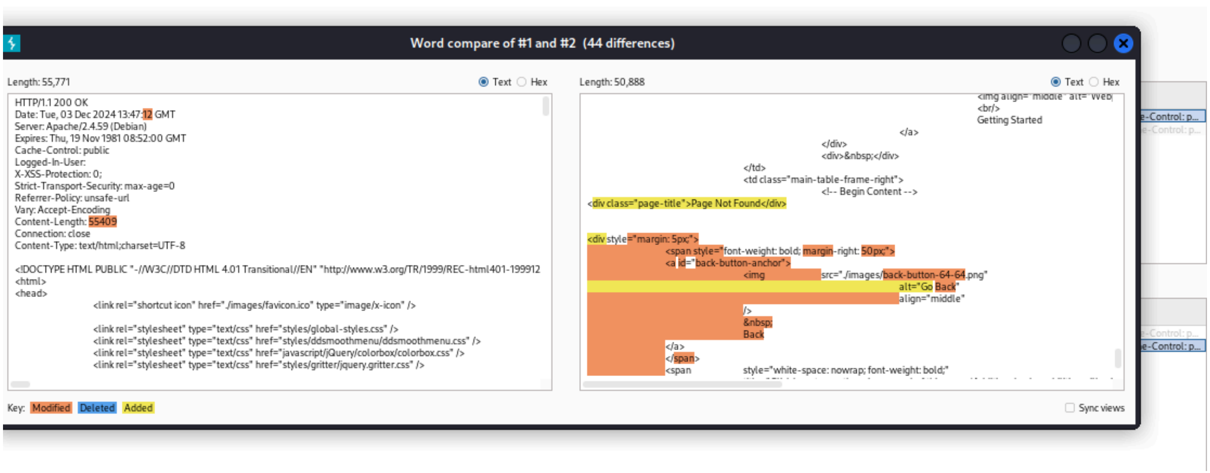
niveau de sécurité mis a 0

question 2




Burp Suite Community Edition v2024.3.1.4 - Temporary Project
Burp Project Intruder Repeater View Help
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn
Send
Cancel
Request
Pretty Raw Hex
GET /mutillidae/index.php?page=home.php&popUpNotificationCode=HPH0 HTTP/1.1
Host: 192.168.200.51
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Referer: http://192.168.200.51/mutillidae/
Connection: close
Cookie: PHPSESSID=bck5dq070bj2ndoct0qj5077gp; showhints=1
Upgrade-Insecure-Requests: 1
Response
Pretty Raw Hex Render
HTTP/1.1 200 OK
Date: Tue, 03 Dec 2024 13:39:38 GMT
Server: Apache/2.4.59 (Debian)
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: public
Logged-In-User:
X-XSS-Protection: 0;
Strict-Transport-Security: max-age=0
Referrer-Policy: unsafe-url
Vary: Accept-Encoding
Content-Length: 55409
Connection: close
Content-Type: text/html;charset=UTF-8
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01 Transitional//EN"
"http://www.w3.org/TR/1999/REC-html401-19991224/loose.dtd">
<html>
<head>
<link rel="shortcut icon" href="./images/favicon.ico" type="image/x-icon" />
<link rel="stylesheet" type="text/css" href="styles/global-styles.css" />
<link rel="stylesheet" type="text/css" href="styles/ddsmoothmenu/ddsmoothmenu.css" />
<link rel="stylesheet" type="text/css" href="javascript/jQuery/colorbox/colorbox.css" />
Search
0 highlights
Search
0 highlights


Burp Suite Community Edition v2024.3.1.4 - Temporary Project
Burp Project Intruder Repeater View Help
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn
Comparer
This function lets you do a word- or byte-level comparison between different data. You can load, paste, or send data here from other tools and then select the comparison you want to perform.
Select item 1:
Length Data
1 504 GET /mutillidae/index.php?page=home777.php&popUpNotificationCode=HPH0 HTTP/1.1Host: 192.168.200.5
2 50838 HTTP/1.1 200 OKDate: Tue, 03 Dec 2024 13:43:26 GMTServer: Apache/2.4.59 (Debian)Expires: Thu, 19 Nov 19
3 55771 HTTP/1.1 200 OKDate: Tue, 03 Dec 2024 13:45:14 GMTServer: Apache/2.4.59 (Debian)Expires: Thu, 19 Nov 19
Select item 2:
Length Data
1 504 GET /mutillidae/index.php?page=home777.php&popUpNotificationCode=HPH0 HTTP/1.1Host: 192.168.200.5
2 50838 HTTP/1.1 200 OKDate: Tue, 03 Dec 2024 13:43:26 GMTServer: Apache/2.4.59 (Debian)Expires: Thu, 19 Nov 19
3 55771 HTTP/1.1 200 OKDate: Tue, 03 Dec 2024 13:45:14 GMTServer: Apache/2.4.59 (Debian)Expires: Thu, 19 Nov 19


Word compare of #1 and #2 (44 differences)
Length: 55,771
Text Hex
HTTP/1.1 200 OK
Date: Tue, 03 Dec 2024 13:47:12 GMT
Server: Apache/2.4.59 (Debian)
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: public
Logged-In-User:
X-XSS-Protection: 0;
Strict-Transport-Security: max-age=0
Referrer-Policy: unsafe-url
Vary: Accept-Encoding
Content-Length: 55409
Connection: close
Content-Type: text/html;charset=UTF-8
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01 Transitional//EN" "http://www.w3.org/TR/1999/REC-html401-199912
<html>
<head>
<link rel="shortcut icon" href="./images/favicon.ico" type="image/x-icon" />
<link rel="stylesheet" type="text/css" href="styles/global-styles.css" />
<link rel="stylesheet" type="text/css" href="styles/ddsmoothmenu/ddsmoothmenu.css" />
<link rel="stylesheet" type="text/css" href="javascript/jQuery/colorbox/colorbox.css" />
<link rel="stylesheet" type="text/css" href="styles/gritter/jquery.gritter.css" />
Length: 50,888
Text Hex

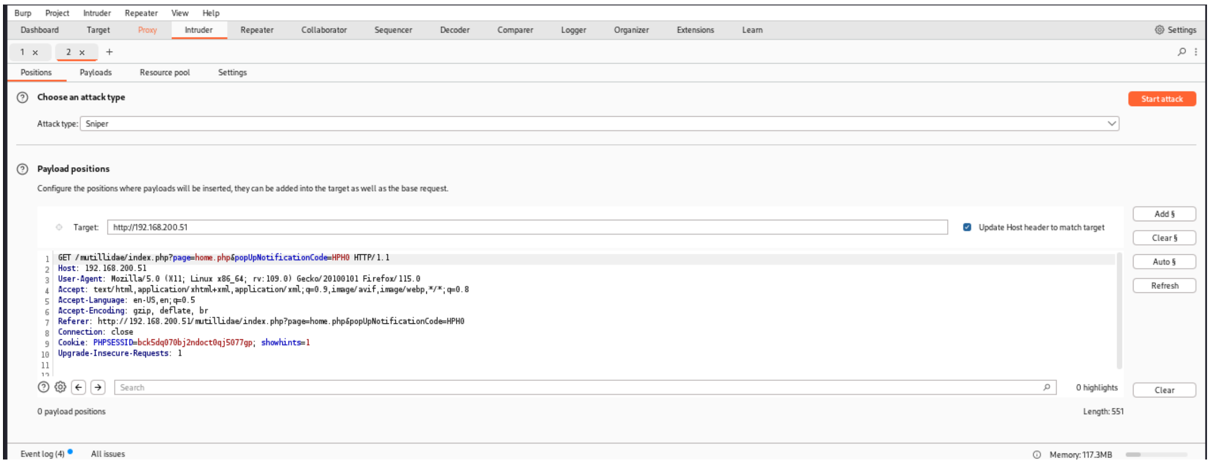
Getting Started

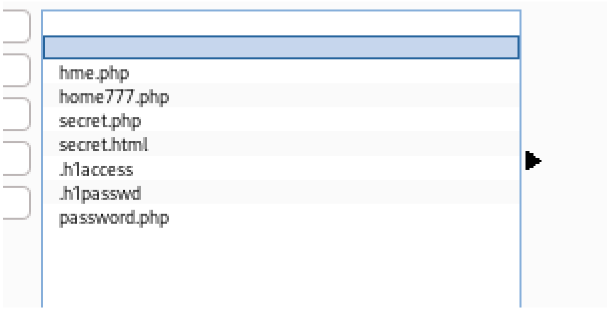
</div>
<div> </div>
</td>
<td class="main-table-frame-right">
<!-- Begin Content -->
<div class="page-title">Page Not Found</div>
<div style="margin: 5px;">

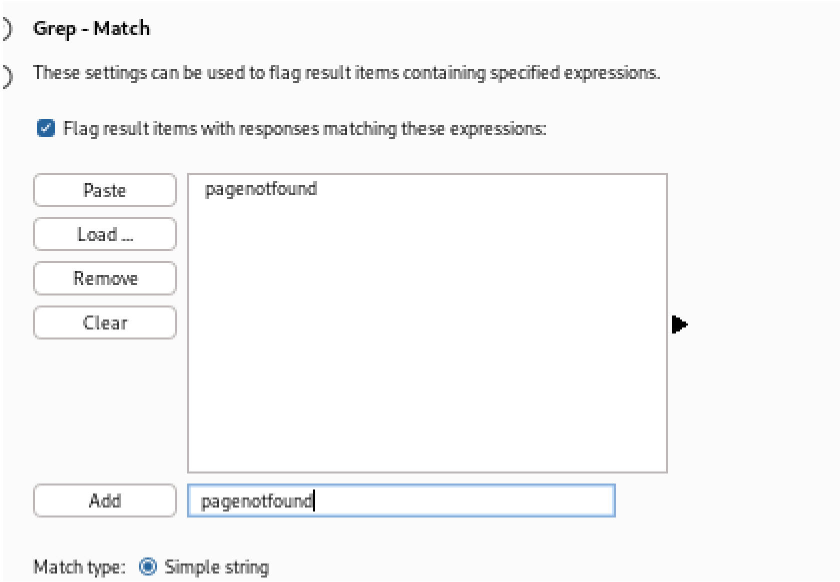
<img src="./images/back-button-64-64.png"
alt="Go Back"
align="middle"
/>

Back

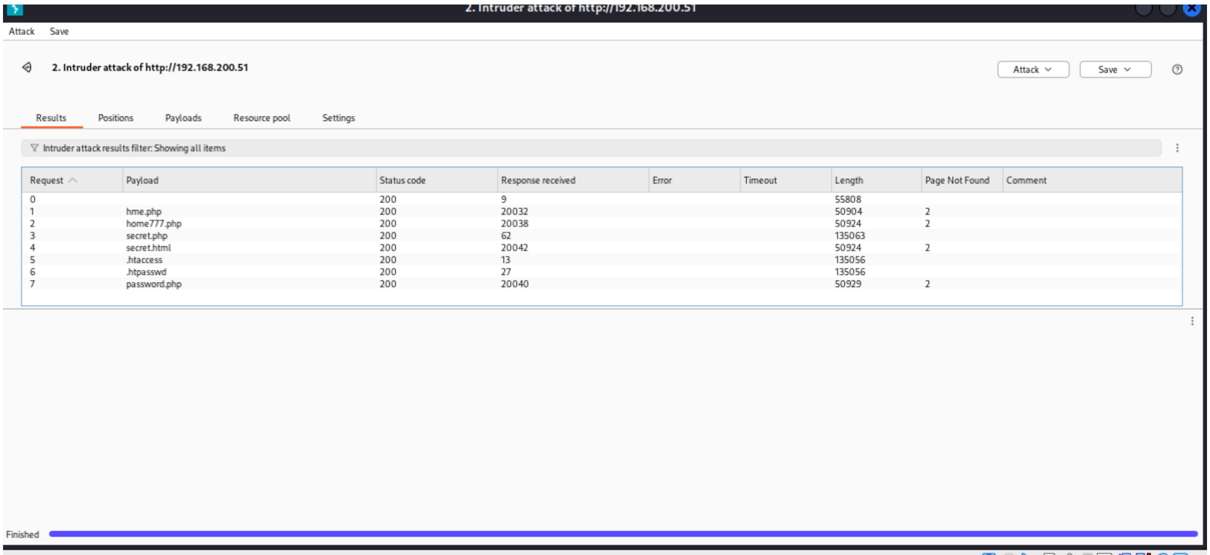
<span style="white-space: nowrap; font-weight: bold;"
Key: Modified Deleted Added
Sync views


Burp Project Intruder Repeater View Help
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn
Settings
Positions Payloads Resource pool Settings
Choose an attack type
Start attack
Attack type: Sniper
Payload positions
Configure the positions where payloads will be inserted, they can be added into the target as well as the base request.
Target: http://192.168.200.51
Update Host header to match target
Add §
Clear §
Auto §
Refresh
GET /mutillidae/index.php?page=home.php&popUpNotificationCode=HPH0 HTTP/1.1
Host: 192.168.200.51
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Referer: http://192.168.200.51/mutillidae/index.php?page=home.php&popUpNotificationCode=HPH0
Connection: close
Cookie: PHPSESSID=bck5dq070bj2ndoct0qj5077gp; showhints=1
Upgrade-Insecure-Requests: 1
Search
0 highlights
Clear
0 payload positions
Length: 551
Event log (4)
All issues
Memory: 117.3MB

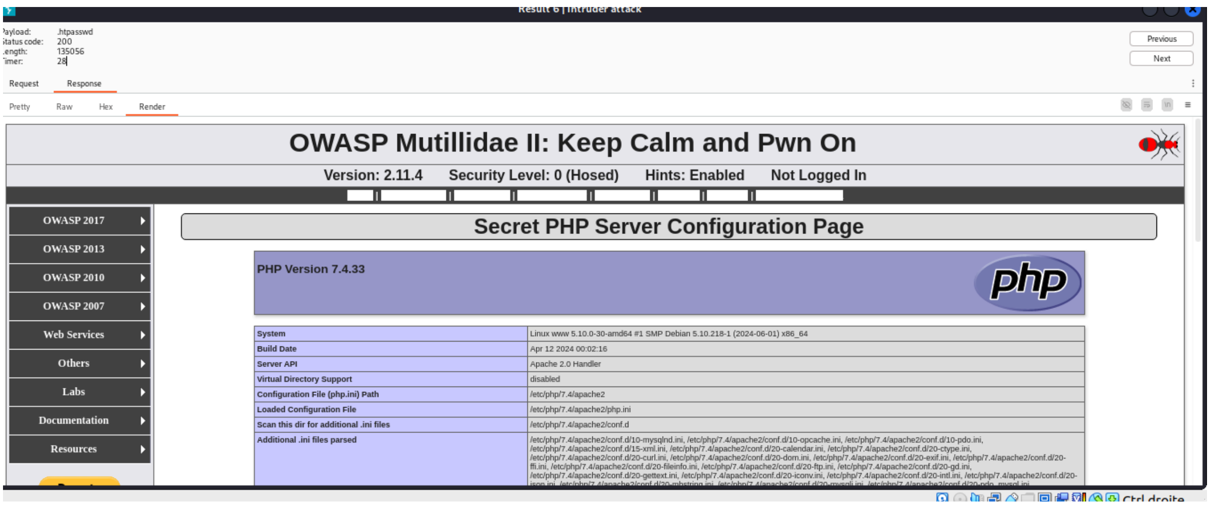

hme.php
home777.php
secret.php
secret.html
.h1access
.h1passwd
password.php



Grep - Match
These settings can be used to flag result items containing specified expressions.
Flag result items with responses matching these expressions:
Paste
Load ...
Remove
Clear
pagenotfound
Add
pagenotfound
Match type:
Simple string



2. Intruder attack of http://192.168.200.51
Attack
Save
2. Intruder attack of http://192.168.200.51
Attack
Save
Results
Positions
Payloads
Resource pool
Settings
Intruder attack results filter: Showing all items
Request | Payload | Status code | Response received | Error | Timeout | Length | Page Not Found | Comment
0 | | 200 | 9 | | | 55808 | |
1 | hme.php | 200 | 20032 | | | 50904 | 2 |
2 | home777.php | 200 | 20038 | | | 50924 | 2 |
3 | secret.php | 200 | 62 | | | 135063 | |
4 | secret.html | 200 | 20042 | | | 50924 | 2 |
5 | .htaccess | 200 | 13 | | | 135056 | |
6 | .htpasswd | 200 | 27 | | | 135056 | |
7 | password.php | 200 | 20040 | | | 50929 | 2 |
Finished



Result 6 | Intruder attack
Payload: .htpasswd
Status code: 200
Length: 135056
Timer: 28
Previous
Next
Request
Response
Pretty
Raw
Hex
Render
OWASP Mutillidae II: Keep Calm and Pwn On
Version: 2.11.4 Security Level: 0 (Hosed) Hints: Enabled Not Logged In
OWASP 2017
OWASP 2013
OWASP 2010
OWASP 2007
Web Services
Others
Labs
Documentation
Resources
Secret PHP Server Configuration Page
PHP Version 7.4.33
php
System | Linux www 5.10.0-30-amd64 #1 SMP Debian 5.10.218-1 (2024-06-01) x86_64
Build Date | Apr 12 2024 00:02:16
Server API | Apache 2.0 Handler
Virtual Directory Support | disabled
Configuration File (php.ini) Path | /etc/php/7.4/apache2
Loaded Configuration File | /etc/php/7.4/apache2/php.ini
Scan this dir for additional .ini files | /etc/php/7.4/apache2/conf.d
Additional .ini files parsed | /etc/php/7.4/apache2/conf.d/10-mysqlnd.ini, /etc/php/7.4/apache2/conf.d/10-opcache.ini, /etc/php/7.4/apache2/conf.d/10-pdo.ini, /etc/php/7.4/apache2/conf.d/15-xml.ini, /etc/php/7.4/apache2/conf.d/20-calendar.ini, /etc/php/7.4/apache2/conf.d/20-ctype.ini, /etc/php/7.4/apache2/conf.d/20-curl.ini, /etc/php/7.4/apache2/conf.d/20-dom.ini, /etc/php/7.4/apache2/conf.d/20-exif.ini, /etc/php/7.4/apache2/conf.d/20-ffi.ini, /etc/php/7.4/apache2/conf.d/20-fileinfo.ini, /etc/php/7.4/apache2/conf.d/20-ftp.ini, /etc/php/7.4/apache2/conf.d/20-gd.ini, /etc/php/7.4/apache2/conf.d/20-gettext.ini, /etc/php/7.4/apache2/conf.d/20-iconv.ini, /etc/php/7.4/apache2/conf.d/20-intl.ini, /etc/php/7.4/apache2/conf.d/20-
Ctrl droite

Travail a faire 2

question 1

Non le niveau 1 de sécurité ne permet pas d'éviter la brèche d'information

question 2

oui le niveau 5 de sécurité permet d'éviter la brèche d'information

question 3

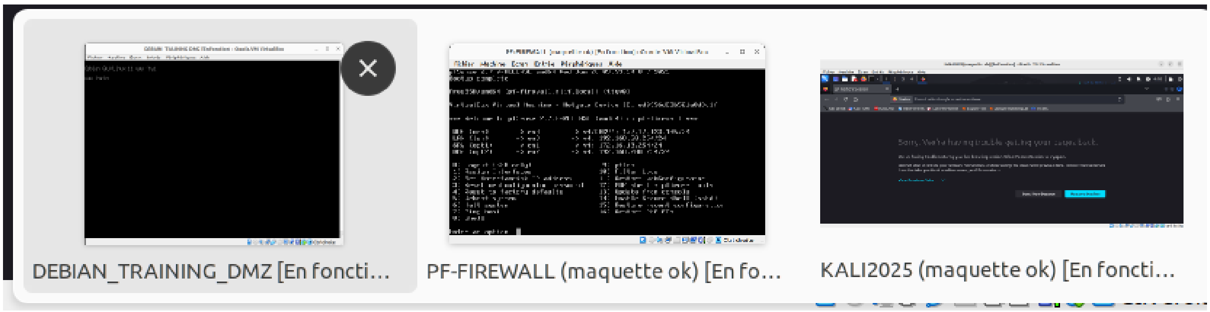
Le mécanisme de sécurité dans le code source limite l'accès à la page via des contrôles d'authentification et d'autorisation. Seuls les utilisateurs ayant les droits appropriés peuvent y accéder. Les autres sont redirigés ou bloqués. Donc, tous les utilisateurs non autorisés n'ont pas accès à cette page.

question 4

Pour empêcher tout utilisateur, y compris l'administrateur, d'accéder à une page spécifique par le Web via la configuration du fichier php.ini, vous pouvez définir une restriction avec la directive open_basedir. Par exemple, en ajoutant la ligne suivante dans le fichier php.ini : open_basedir = /var/www/html:/tmp:/etc/php/7.0/apache2/, vous limitez l'accès des scripts PHP aux répertoires spécifiés, empêchant ainsi l'exécution des fichiers PHP dans d'autres répertoires accessibles par le Web. Il est également conseillé de déplacer la page en question hors de la racine du serveur Web pour renforcer la sécurité.

Travail a faire 3

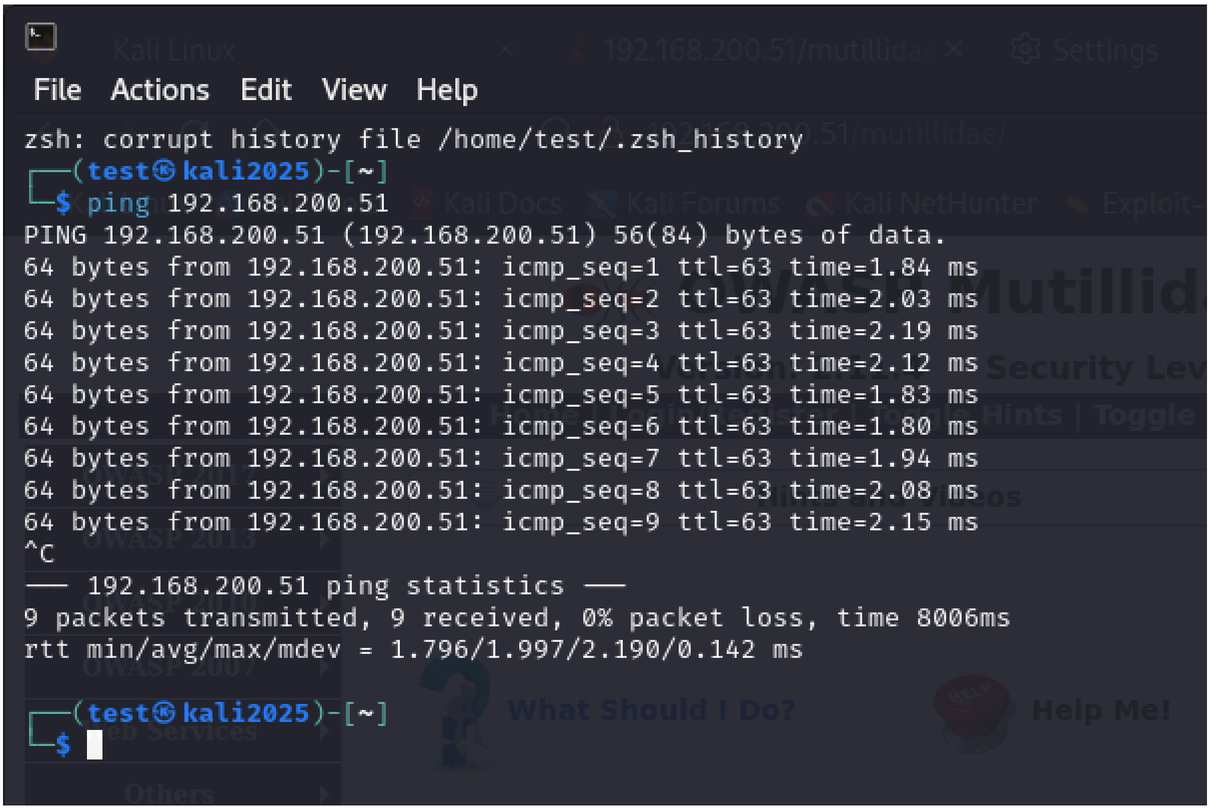
question 1



3 machine allumée

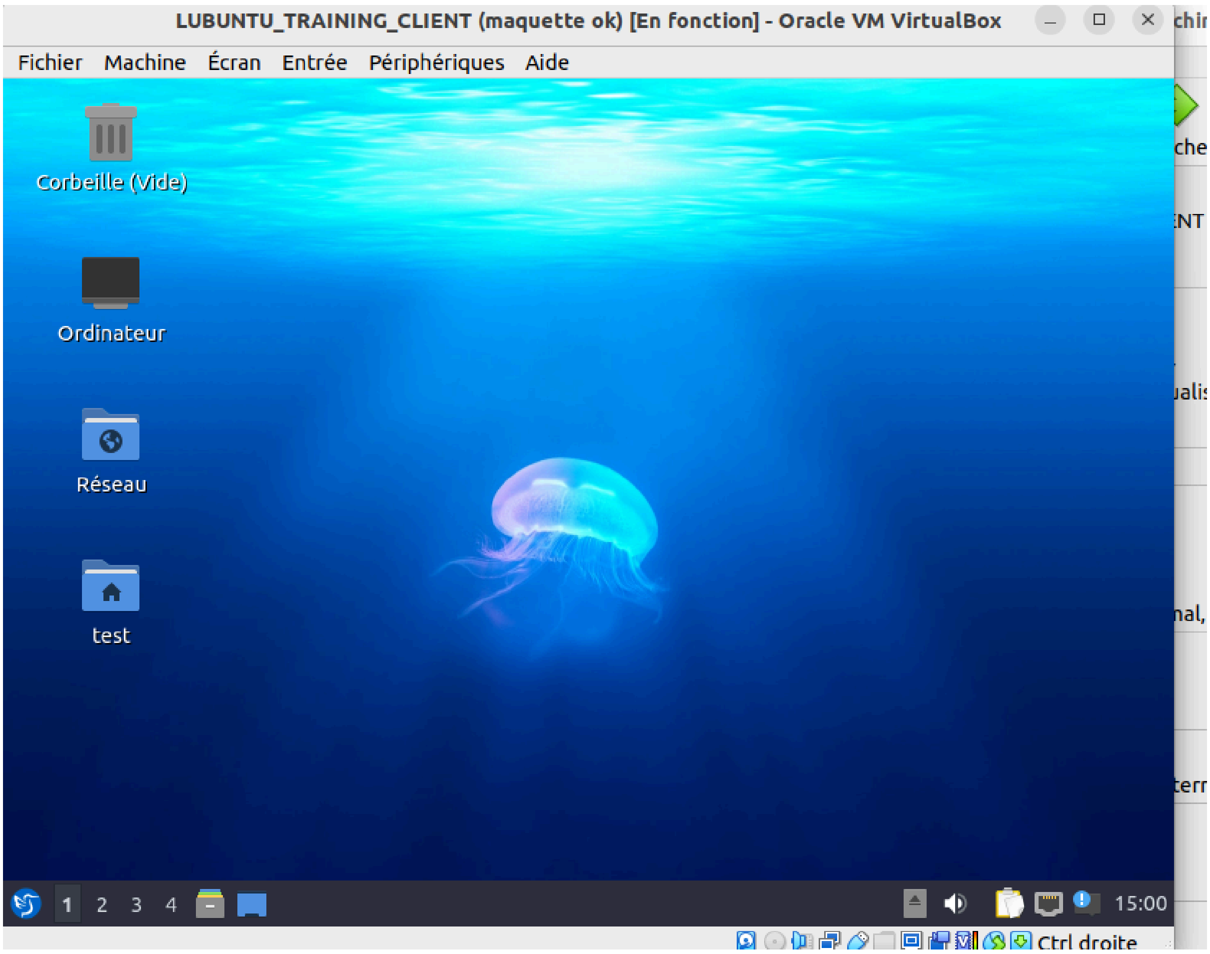
mis au niveau 0

ping de la machine cliente vers la dmz


File Actions Edit View Help
zsh: corrupt history file /home/test/.zsh_history
┌──(test㉿kali2025)-[~]
└─$ ping 192.168.200.51
PING 192.168.200.51 (192.168.200.51) 56(84) bytes of data.
64 bytes from 192.168.200.51: icmp_seq=1 ttl=63 time=1.84 ms
64 bytes from 192.168.200.51: icmp_seq=2 ttl=63 time=2.03 ms
64 bytes from 192.168.200.51: icmp_seq=3 ttl=63 time=2.19 ms
64 bytes from 192.168.200.51: icmp_seq=4 ttl=63 time=2.12 ms
64 bytes from 192.168.200.51: icmp_seq=5 ttl=63 time=1.83 ms
64 bytes from 192.168.200.51: icmp_seq=6 ttl=63 time=1.80 ms
64 bytes from 192.168.200.51: icmp_seq=7 ttl=63 time=1.94 ms
64 bytes from 192.168.200.51: icmp_seq=8 ttl=63 time=2.08 ms
64 bytes from 192.168.200.51: icmp_seq=9 ttl=63 time=2.15 ms
^C
--- 192.168.200.51 ping statistics ---
9 packets transmitted, 9 received, 0% packet loss, time 8006ms
rtt min/avg/max/mdev = 1.796/1.997/2.190/0.142 ms
┌──(test㉿kali2025)-[~]
└─$

question 2

```
root@www:~# a2enmod ssl
Considering dependency setenvif for ssl:
Module setenvif already enabled
Considering dependency mime for ssl:
Module mime already enabled
Considering dependency socache_shmcb for ssl:
Enabling module socache_shmcb.
Enabling module ssl.
See /usr/share/doc/apache2/README.Debian.gz on how to configure SSL and create self-signed cer
tes.
To activate the new configuration, you need to run:
  systemctl restart apache2
root@www:~# a2ensite default-ssl.conf
Enabling site default-ssl.
To activate the new configuration, you need to run:
  systemctl reload apache2
root@www:~# service apache2 restart
root@www:~#
```



```
[sudo] password for test:
┌──(root㉿kali2025)-[/home/test]
└─# apt install dsniff sslstrip
dsniff is already the newest version (2.4b1+debian-33).
Installing:
  sslstrip

Summary:
  Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 159
  Download size: 12.1 kB
  Space needed: 61.4 kB / 63.7 GB available

Continue? [Y/n] y
Get:1 http://http.kali.org/kali kali-rolling/main amd64 sslstrip all 1.0+git20211
125.9ac747b-0kali2 [12.1 kB]
Fetched 12.1 kB in 1s (14.9 kB/s)
Selecting previously unselected package sslstrip.
(Reading database ... 390905 files and directories currently installed.)
Preparing to unpack .../sslstrip_1.0+git20211125.9ac747b-0kali2_all.deb ...
Unpacking sslstrip (1.0+git20211125.9ac747b-0kali2) ...
Setting up sslstrip (1.0+git20211125.9ac747b-0kali2) ...
Processing triggers for man-db (2.12.1-1) ...
Processing triggers for kali-menu (2023.4.7) ...
```

```
┌──(root㉿kali2025)-[/home/test]
└─# iptables -t nat -A PREROUTING -p tcp --destination-port 80 -j REDIRECT --to-port 7777
```